user’s action through the tenant PDP and back to the system policy that governed it.

These internal pilots confirmed that externalized authorization wasn’t just theoretical: it enabled C³ to operate securely across multiple trust boundaries using a single consistent evaluation model.

APPLYING THESE PATTERNS OUTSIDE OF SAAS

Although C³ is presented as a multi-tenant SaaS platform, the authorization patterns in this chapter are not exclusive to SaaS systems. The main idea is layered authorization across multiple trust boundaries, not tenancy itself. In enterprise and zero-trust environments, those boundaries often correspond to business units, environments, or clearance domains rather than customers.

ACME encountered this firsthand when it applied the same architecture internally. Before C³ became a product, ACME used an ABAC-style model to manage access to deployment tools and internal systems. The “global” policy layer enforced enterprise-wide requirements such as managed devices and on-call status, while application-level policies controlled access to specific tools. When ACME later introduced tenant-aware sharing through ReBAC, those new policies fit within the same structure instead of replacing it.

In both cases, the basic process is the same: policy decisions are externalized, evaluated by PDPs using a shared schema, and enforced by PEPs close to the protected resources. What changes is the form of the data—attributes in an ABAC system, relationships in a ReBAC system—not the architecture that evaluates them.

13.7 Putting lessons into practice

Transforming the Customer Collaboration platform into the Customer Collaboration Cloud taught ACME more than just how to externalize authorization; it uncovered what makes a policy-based architecture